AcmeCorp Accounts - Design Explanation

1. Problem & stack

We built an accounts console that (A) manages org/customers/invoices, (B) sends overdue reminders and safely answers inbound mail with an LLM behind hard gates, and (C) reconciles bank CSV credits to open invoices. Stack: FastAPI + Motor/MongoDB + Next.js (server proxy injects X-Admin-Token). Money is integer minor units end-to-end; DEMO_TODAY freezes "today" for overdue demos.

2. Matching pipeline (Part C)

Goal: prefer no-match over a wrong match. No statement text is sent to an LLM by default.

1. Normalize narration -> payer string + invoice hints (strong INV-####, weak RE/REF/bare digits).
2. Aliases per customer: legal-suffix strip, abbreviations (PKG/packaging), contact-name initials.
3. Similarity: blend of RapidFuzz token_set_ratio, Jaro-Winkler, and character n-gram TF-IDF cosine. Embeddings optional and off.
4. Candidates: open invoices only; multi-invoice subset-sum (same customer + currency, size 2-5, combination cap).
5. Score (approx. 100-point scale before caps):

confidence ~ invoice_ref + 0.35xpayer_sim + amount_factorx28 + date + synergy

- Explicit invoice ref ~ 38; weak hint ~ 18.
- Amount factors: exact outstanding/TDS = 1.0; exact total 0.9; partial 0.72; overpay 0.15 (then refused).
- Synergy (+8, or half for typo'd but gated payers) when payer clears the gate and amount is exact/TDS/partial.

6. Hard gates (kept): currency mismatch; payment date before invoice_date; unknown payer + no invoice hint; amount alone; weak bare-number UTR without payer (cap below review); overpay never auto-suggested; conflict (hint customer != payer) capped. Confidence under 60 becomes none with soft top-3 alternatives for the reviewer.
7. Rejected techniques: statement->LLM as primary matcher (non-deterministic, data leak risk); embeddings as default (heavy, marginal gain on this corpus); amount-only matching (catastrophic false positives across equal open balances).
8. Idempotency: sha256(date|narration|amount_minor|reference|currency); if already applied on any statement -> already_applied / approve 409.
9. Bonus: inbound "paid INV-..." / UTR claims store evidence shown on statement rows and add a +5 boost only to candidates that already cleared gates - never enough to create a match alone.

Eval / stress tests (self-authored): the held-out adversarial CSV (eval_holdout.csv, 40+ rows) and the mutation stress suite were written by us without looking at matcher thresholds. Holdout: precision = recall = 1.0 (no wrong/missed rows). Mutation stress (test_matching_mutation.py, seed 20261105): from 48 correctly matched base rows, 271 mutations -> 254 same / 17 downgraded-to-none / 0 wrong. Policy for exact-tie sibling invoices (same customer, same amount, no hint): suggest earliest due under the review band (confidence capped below high), and name every sibling in the reason and alternatives. Merged digit runs (RE 10-25) are weak open-suffix hints only; bare dates / UTR digit soup must not invent invoice hints.

3. Collections agent (Part B)

Outbound reminders: overdue (status=sent, balance > 0, due before today) only; one email per customer; facts from DB templates; subject token [AC-...]; cooldown; overlap lock.

Inbound order: Message-ID dedupe -> auto-reply/bounce headers -> resolve conversation (In-Reply-To ->

[AC-...] -> sender email) -> strip quoted history -> keyword safety (legal / dispute / extension / other customer) -> LLM JSON (tolerant of fences/prose; pydantic-validated; retry once) with only this customer's unpaid sent invoices -> compose (code facts + LLM prose) -> validator (invoice #s, amounts, dates, no foreign names/banks, no paid/waiver promises) -> SMTP or Needs attention.

Unknown senders and other-company mentions get nothing. Claims of payment never mark invoices paid. Mixed intents escalate entirely.

4. Architecture & security

Browser -> Next.js allowlisted proxy -> FastAPI -> Mongo. Secrets stay server-side. Production refuses weak admin tokens. CORS is a single origin. Uploads capped (2 MB CSV). Rate limits on upload/inbox/reminders. SMTP strips CR/LF in headers. Email bodies are not written to application logs.

5. Limitations

No unapplied-credit ledger (overpay refused). Human Needs-attention send warns instead of hard-blocking. Schedulers off by default. Matcher still imperfect on pathological lookalikes; we bias to none. Live Gmail/LLM quality depends on operator credentials and provider JSON behaviour.